KAIRON

SOC gestionado para particulares y empresas

Capítulo 2 · Diseño del Proyecto

Actividad ACT1 RA2 · Módulo 1713 SMR 2.º · Digitech Barcelona · Entrega: 12-11-2026
Equipo: Antonia Lorena Cracana (ciberseguridad y forense) · João Daniel de Paiva Oliveira (programación y web)

> **Nota.** KAIRON es una empresa **ficticia** creada para este proyecto. Los precios, los clientes y las cifras de negocio de este capítulo son una simulación razonada con supuestos explícitos; los datos técnicos (Wazuh, pfSense, puertos, requisitos) son los reales del laboratorio que se va a montar.

2.1 Propuesta global y viabilidad técnica

Descripción del contenido

KAIRON es una empresa de ciberseguridad que ofrece un **SOC (centro de operaciones de seguridad) gestionado por suscripción**: vigila de forma continua los equipos de sus clientes, detecta ataques a tiempo y responde en el momento oportuno, que es lo que significa *kairos* en griego. El problema que resuelve es real: los particulares, los autónomos y las pymes sufren los mismos ataques que las grandes empresas (ransomware, phishing, fuerza bruta) pero no pueden pagar ni mantener un equipo de seguridad propio.

El proyecto consiste en **diseñar, montar y demostrar en un laboratorio virtual aislado la tecnología que sostiene ese servicio**: un SIEM Wazuh que recoge los registros de agentes instalados en equipos Windows y Linux, un cortafuegos pfSense que segmenta la red, reglas de detección propias, respuesta activa automática y una **herramienta forense propia en Python** que recoge las pruebas del equipo afectado con cadena de custodia (hora UTC, número de caso y hash SHA-256 de cada prueba). La web corporativa de KAIRON, ya entregada en la práctica A1-RA1, es la cara pública del servicio.

El servicio se comercializa en **cuatro planes** que usan la misma tecnología y cambian en la cantidad de atención humana: tres accesibles para el público general —**Vigía (9,90 €/mes), Centinela (24,90 €/mes) y Guardián (64,90 €/mes)**, IVA incluido— y una versión para empresas, **Égida, desde 590 €/mes + IVA**. La demostración del TFG recorre un caso completo: un ataque simulado (fuerza bruta contra SSH y un ejecutable simulado con persistencia en Windows), su detección por Wazuh, la contención automática, la recogida de pruebas y el informe final. Quedan **fuera del alcance** KAIRON Data Chip y KAIRON Agents, que se presentan como líneas futuras.

2.1.1 Estudio de viabilidad técnica

La tecnología elegida es adecuada porque cada pieza cubre una función concreta, se integra con las demás por protocolos estándar y no exige licencias de pago, que es lo que permite fijar un plan de entrada de 9,90 €.

Criterio	Justificación técnica
Idoneidad	Wazuh es un SIEM/XDR de código abierto con agentes para Windows, Linux y macOS, monitorización de integridad de archivos, detección de vulnerabilidades, reglas personalizables y respuesta activa. Cubre las funciones de detección y respuesta del servicio sin coste de licencia. pfSense CE aporta cortafuegos, segmentación y VPN, también de código abierto.
Compatibilidad	Los agentes envían los eventos al manager por el puerto 1514/TCP cifrado; pfSense reenvía su registro a Wazuh por syslog (514/UDP); Sysmon enriquece los eventos de Windows; la herramienta forense usa Python 3 (biblioteca estándar y psutil) y funciona igual en Windows y Linux. Todo corre en máquinas virtuales de VirtualBox, sin hardware especial.

Criterio	Justificación técnica
Escalabilidad	La documentación oficial de Wazuh dimensiona un despliegue todo en uno así: 1–25 agentes con 4 vCPU, 8 GB de RAM y 50 GB de disco (90 días de datos); 26–50 agentes con 8 vCPU, 16 GB y 100 GB; 51–100 agentes con 8 vCPU, 16 GB y 200 GB. A partir de 100 agentes se pasa a un despliegue distribuido en varios nodos, por lo que el coste de infraestructura crece de forma lineal y previsible (ver 2.3.1).
Eficiencia	El agente es ligero; las reglas se ajustan a cada cliente para reducir falsos positivos; la respuesta activa bloquea al atacante en segundos sin intervención humana; los informes se generan con la herramienta propia, lo que reduce las horas de analista por cliente.
Puesta en marcha	Existe una máquina virtual OVA oficial de Wazuh ya preinstalada, lo que elimina el principal riesgo de instalación. El plan del TFG prevé un corte de alcance (lo que no funcione se quita) y un vídeo de respaldo de la demo.
Límites asumidos	Wazuh no ofrece agente para móviles: los planes cubren ordenadores y servidores. El servicio es en horario laboral ampliado con alertas automáticas fuera de horario; no se promete vigilancia humana 24/7. La herramienta forense actúa sobre el equipo afectado y no sustituye a un laboratorio forense completo.

2.2 Definición de objetivos y recursos

2.2.1 Objetivos

Objetivo general. Diseñar, implantar y demostrar en un laboratorio virtual aislado un SOC gestionado de bajo coste (Wazuh, pfSense y una herramienta forense en Python) que detecte un ataque simulado, responda automáticamente y lo documente con cadena de custodia, y definir su comercialización en cuatro planes económicamente viables, con el caso completo funcionando de principio a fin.

Objetivos específicos (medibles y verificables en el laboratorio):

- **OE1.** **Laboratorio.** Montar en VirtualBox, repartidas en dos PCs, las 5 máquinas virtuales obligatorias y las 4 redes descritas en 2.4.4, con conectividad comprobada según la tabla de reglas del cortafuegos, y conectar al menos 3 agentes Wazuh en estado *Active*.
- **OE2.** **Detección de fuerza bruta.** Una regla propia (ID 100100) genera una alerta de nivel 10 en menos de 60 segundos cuando una misma IP acumula 5 fallos de acceso SSH en 60 segundos.
- **OE3.** **Detección de malware y persistencia.** Detectar en el equipo Windows la ejecución de un ejecutable simulado y la creación de su persistencia (tarea programada o clave Run del registro) con una alerta de nivel igual o superior a 10.
- **OE4.** **Respuesta activa y vuelta atrás.** Bloquear automáticamente la IP atacante en un máximo de 30 segundos desde la alerta y desbloquearla sola a los 10 minutos, sin dejar reglas huérfanas en el cortafuegos.
- **OE5.** **Herramienta forense.** Entregar una herramienta en Python con 4 módulos (procesos, conexiones de red, usuarios e inicios de sesión, persistencia) que se ejecute en menos de 5 minutos y marque el 100 % de las pruebas con hora UTC, número de caso y SHA-256.
- **OE6.** **Informe de incidente.** Generar un informe en JSON y Markdown con cronología, evidencias y recomendaciones, cuyo hash recalculado coincida en el 100 % de las pruebas.
- **OE7.** **Demo de principio a fin.** Ejecutar el caso completo (ataque, alerta, contención, recogida de pruebas e informe) 3 veces seguidas sin fallos y grabar un vídeo de respaldo de 3 minutos.
- **OE8.** **Viabilidad económica.** Demostrar con números que cada uno de los cuatro planes tiene margen positivo (al menos un 30 % en los tres planes para particulares) y que el punto de equilibrio se alcanza con 19 clientes del plan más barato o menos.

2.2.2 Recursos hardware

El laboratorio se reparte en **dos PCs de 16 GB de RAM y 500 GB de disco**, porque las máquinas virtuales juntas superan la memoria de un solo equipo. El **PC-A (Lorena)** aloja el SOC (Wazuh) y el **PC-B (Dani)** aloja el cortafuegos, los equipos del cliente simulado y la máquina atacante. Los dos se unen con un cable Ethernet directo (apartado 2.4.1). Las cifras son las **especificaciones mínimas**.

Equipo / VM	Función	vCPU	RAM	Disco	Red
PC-A (Lorena)	Anfitrión del SOC: VirtualBox 7 y navegador para el panel de Wazuh	8 hilos	16 GB	500 GB SSD	Cable directo + Wi-Fi para Internet
PC-B (Dani)	Anfitrión del cliente simulado y del atacante: VirtualBox 7	8 hilos	16 GB	500 GB SSD	Cable directo + Wi-Fi para Internet
VM Wazuh (PC-A)	SIEM todo en uno (manager, indexer y dashboard) desde la OVA oficial	4	8 GB	50 GB	SOC (adaptador puente al cable)
VM pfSense CE (PC-B)	Cortafuegos, router, DHCP, DNS, NTP y VPN WireGuard	1	1 GB	10 GB	WAN (NAT), LAN, Ataque, SOC
VM Ubuntu Server 24.04 (PC-B)	Servidor Linux: SSH, web (nginx), objetivo del ataque de fuerza bruta	2	2 GB	25 GB	LAN
VM Windows 10/11, cliente 1 (PC-B)	Equipo de usuario: agente Wazuh, Sysmon, objetivo del ejecutable simulado	2	4 GB	50 GB	LAN
VM Kali Linux (PC-B)	Máquina atacante (Hydra, scripts de ataque)	2	4 GB	40 GB	Ataque
VM Windows Server 2022, cliente 2 (PC-B, opcional)	Segundo Windows: servicios de dominio y RDP	2	4 GB	50 GB	LAN
Uso del PC-A	Solo Wazuh; queda margen para el sistema anfitrión	**4**	**8 GB**	**50 GB**	—
Uso del PC-B	Sin el cliente 2 opcional	**7**	**11 GB**	**125 GB**	—

Tabla 1. Recursos hardware del laboratorio. Con 16 GB, el PC-B no admite las cinco máquinas a la vez con el cliente 2 opcional (15 GB de máquinas más el sistema): este solo se enciende apagando Kali o el cliente 1. El disco se asigna de forma dinámica.

Para la fase comercial (fuera del TFG) se parte del dimensionamiento oficial de Wazuh, que es la referencia del coste de infraestructura de 2.3.1:

Agentes protegidos	vCPU	RAM	Disco (90 días)	Despliegue
1–25	4	8 GB	50 GB	Servidor único (todo en uno)
26–50	8	16 GB	100 GB	Servidor único
51–100	8	16 GB	200 GB	Servidor único
Más de 100	—	—	—	Despliegue distribuido en varios nodos

Tabla 2. Dimensionamiento de producción (fuente: documentación oficial de Wazuh, quickstart).

Docker. El laboratorio no usa contenedores: Wazuh se despliega desde la OVA oficial y el resto son máquinas completas, para poder instalar agentes y atacar sistemas reales. Wazuh dispone también de un despliegue en Docker de un solo nodo, que se valorará para la fase comercial por su facilidad de reproducción.

2.2.3 Recursos software

Software	Versión	Uso en el proyecto	Licencia
Wazuh (manager, indexer, dashboard, agentes)	4.x	SIEM: recogida, correlación, alertas y respuesta activa	Open Source (GPLv2 y Apache 2.0)
pfSense CE	2.7 / 2.8	Cortafuegos, segmentación, DHCP, DNS, NTP, WireGuard	Open Source (Apache 2.0)
Oracle VirtualBox	7.x	Hipervisor del laboratorio	Open Source (GPLv2); Extension Pack gratuito para uso educativo
Ubuntu Server LTS	24.04	Servidor Linux objetivo; nginx y OpenSSH	Open Source
Kali Linux	2025/2026	Máquina atacante en entorno aislado	Open Source
Windows 10/11 Enterprise y Windows Server 2022	Evaluación	Equipos Windows del laboratorio (ISO de evaluación de Microsoft, 90 a 180 días)	Comercial (evaluación gratuita)
Sysmon (Sysinternals)	15.x	Telemetría detallada de procesos y red en Windows	Propietario, gratuito
Fail2ban	1.x	Bloqueo de intentos de acceso SSH repetidos	Open Source (GPLv2)
WireGuard	—	VPN de acceso remoto de analistas a la red de gestión	Open Source (GPLv2)
Python 3 + psutil	3.12	Herramienta forense (hash con hashlib, informes JSON y Markdown)	Open Source (PSF y BSD-3)
PyInstaller	6.x	Empaquetar la herramienta en un ejecutable	Open Source (GPLv2 con excepción)
Git y GitHub	—	Control de versiones, etiquetas de versión y publicación con GitHub Pages	Open Source (Git); servicio gratuito
HTML5, CSS3 y JavaScript; Three.js, GSAP y Lenis	0.160 / 3.12 / 1.1	Web corporativa (librerías de JavaScript en local, sin CSS externo)	Open Source (MIT) / GSAP: licencia gratuita
Visual Studio Code	—	Editor de código	Gratuito (código abierto con binario Microsoft)

Tabla 3. Software y licencias. Ninguna pieza exige licencia de pago, de modo que el coste de software es prácticamente nulo.

2.2.4 Recursos personales

Integrante	Rol	Responsabilidades	Dedicación
Antonia Lorena Cracana	Responsable de ciberseguridad y análisis forense	Diseño y montaje del laboratorio, Wazuh y pfSense, reglas de detección, ataques simulados, definición de las pruebas y de la cadena de custodia, informes	
João Daniel de Paiva Oliveira	Responsable de programación y web	Herramienta forense en Python (módulos, informe, empaquetado y pruebas), web corporativa, repositorio GitHub y validación W3C	
Ambos	Equipo	Demo del caso completo, memoria, presentación y ensayos	
Tutor/a del módulo	Supervisión	Revisión de la memoria antes de la entrega y validación del alcance	Sin coste para el proyecto

Tabla 4. Equipo y dedicación.

2.3 Estudio de viabilidad económica y presupuesto

2.3.1 Presupuesto estimado

El presupuesto separa dos cosas: lo que **cuesta construir el proyecto** (hardware, software y mano de obra) y lo que **cuesta y rinde operar el servicio** cuando se vende en los cuatro planes. Así se demuestra que el servicio se paga solo.

A. Coste de desarrollo del proyecto

Hardware y software	Coste
PC-A de Lorena, anfitrión del SOC (valor 900 €, amortización 48 meses × 4 meses)	75,00 €
PC-B de Dani, anfitrión del cliente y del atacante (valor 900 €, amortización 48 meses × 4 meses)	75,00 €
SSD externo de 1 TB (copias de seguridad y exportaciones OVA)	75,00 €
Cable Ethernet y adaptador USB-Ethernet para el enlace directo entre los dos PCs	15,00 €
Electricidad e Internet imputados (4 meses)	40,00 €
Subtotal hardware	**280,00 €**
Dominio .es kairon (1 año, opcional para la web)	10,00 €
Licencias de software (Wazuh, pfSense, VirtualBox, Ubuntu, Kali, Python, Git: gratuitas; Windows en evaluación)	0,00 €
Subtotal software	**10,00 €**

Mano de obra por tarea	Lorena (h)	Dani (h)	Coste
Análisis, planificación y diseño (capítulo 2, alcance, red)			
Montaje del laboratorio (VirtualBox, pfSense, Wazuh, agentes)			
Reglas de detección, ataques simulados y respuesta activa			
Herramienta forense en Python (4 módulos, informe, cadena de custodia)			
Web corporativa KAIRON (2 páginas + extras, ya desarrollada)			
Pruebas, ensayos y demo			
Memoria, presentación y documentación			
Total horas · tarifa 20 €/h			

Tabla 5. Horas de ingeniería × tarifa horaria de un técnico junior de sistemas y ciberseguridad (20 €/h).

Resumen del presupuesto de desarrollo	Importe
Hardware (imputado)	280,00 €
Software y dominio	10,00 €
Mano de obra (horas × 20 €/h)	
Subtotal	
Imprevistos (5 %)	
PRESUPUESTO TOTAL DEL PROYECTO	
De los cuales, desembolso real en efectivo (SSD, dominio y cable)	100,00 €

B. Modelo de ingresos: cuatro planes

Los planes para el público general se piensan para tres niveles de bolsillo (unos 10 €, entre 20 y 30 € y entre 60 y 70 € al mes) y la versión para empresas se reserva para clientes que necesitan atención dedicada y pueden pagar más. Los precios a particulares **incluyen IVA (21 %)**; los de empresa se facturan **más IVA**. Ya figuraba en el plan de empresa (página *Productos*) el modelo de «suscripciones para particulares y empresas».

Característica	Vigía	Centinela	Guardián	Égida (empresas)
Pensado para	1–2 equipos: un particular o autónomo	Familia o autónomo con hasta 5 equipos	Teletrabajador o microempresa, hasta 10 equipos	Pymes de 10 a 100 equipos
Precio	**9,90 €/mes IVA incl.**	**24,90 €/mes IVA incl.**	**64,90 €/mes IVA incl.**	**Desde 590 €/mes + IVA +12 €/equipo adicional**
Equipos incluidos	2	5	10	25 (hasta 100)
Agente Wazuh gestionado (Windows, macOS, Linux)	Sí	Sí	Sí	Sí
Detección: fuerza bruta, malware, cambios en archivos críticos	Reglas estándar	Reglas estándar + ajuste inicial	Ajuste continuo	Reglas a medida
Revisión humana de alertas	Solo alertas críticas	Analista, en horario laboral	Analista asignado	Equipo dedicado
Respuesta (L–V, 9–19 h)	2 días laborables	24 h (críticas: 8 h)	4 h	1 h
Respuesta a incidentes	Guía paso a paso	Guía y asistencia remota por chat	Contención remota y 1 caso forense al año	Contención y hasta 2 casos forenses al año
Informes	Resumen mensual de 1 página	Informe mensual	Mensual + informe de incidente con SHA-256	Mensual para dirección + informe trimestral de apoyo al RGPD
Formación	Guía y mini-curso antiphishing	+ sesión online trimestral	+ simulacro de phishing anual	2 sesiones al año para la plantilla
Auditoría y hardening	—	Lista de autocomprobación	Auditoría de hardening anual	Auditoría inicial gratuita + hardening anual
Retención de registros	30 días	90 días	90 días	180 días
Permanencia	Ninguna	Ninguna	Ninguna	12 meses

Tabla 6. Planes de KAIRON. Un caso de ejemplo: Marta (60 equipos) pagaría 590 € + 35 × 12 € = 1.010 € + IVA al mes, unos 16,83 € por equipo, con precio fijo y previsible.

Cómo se cumple lo prometido. Cada fila de la tabla 6 se corresponde con un componente del diseño técnico, de modo que ningún plan promete algo que el laboratorio no demuestre:

Promesa del plan	Componente que la cumple	Dónde se demuestra
Agente gestionado y detección de fuerza bruta, malware y cambios de archivos	Agentes Wazuh, reglas propias (ID 100100 y siguientes), monitorización de integridad, Sysmon	Objetivos 1, 2 y 3
Bloqueo del atacante	Respuesta activa de Wazuh (firewall-drop) con desbloqueo automático	Objetivo 4

Promesa del plan	Componente que la cumple	Dónde se demuestra
Caso forense, informe con SHA-256 y cronología	Herramienta forense en Python con cadena de custodia	Objetivos 5 y 6; informe.html de la web
Retención de 30 a 180 días	Indexer de Wazuh dimensionado según la tabla 2	Apartado 2.2.2
Formación y apoyo al RGPD	Material propio y plantilla de informe de cumplimiento	Servicios de la web y apartado 2.4.6

C. Coste, margen y punto de equilibrio de cada plan

Los costes variables mensuales por cliente se calculan con tres supuestos: **infraestructura de 0,60 € por equipo** (un servidor de 8 vCPU y 16 GB para 100 agentes, unos 50 € al mes, da 0,50 € por agente, más almacenamiento de copias); **analista a 20 €/h**; y **comisión de la pasarela de pago** (0,25 € + 1,5 %; 0,35 € en domiciliación SEPA). Los precios a particulares se comparan **sin IVA**.

Plan	Ingreso neto	Infra.	Analista	Pago	Coste total	Margen	% margen
Vigía	8,18 €	1,20 €	3,33 € (0,17 h)	0,40 €	4,93 €	**3,25 €**	**39,7 %**
Centinela	20,58 €	3,00 €	10,00 € (0,50 h)	0,62 €	13,62 €	**6,96 €**	**33,8 %**
Guardián	53,64 €	6,00 €	30,00 € (1,50 h)	1,22 €	37,22 €	**16,41 €**	**30,6 %**
Égida	590,00 €	15,00 €	160,00 € (8,00 h)	0,35 €	175,35 €	**414,65 €**	**70,3 %**

Tabla 7. Economía unitaria mensual por cliente. Todos los planes tienen margen positivo: 39,7 % en Vigía, 33,8 % en Centinela y 30,6 % en Guardián, y 70,3 % en Égida.

Además de lo variable hay unos **costes fijos de 60 € al mes**: seguro de responsabilidad civil y ciberriesgo (40 €); dominio, web y correo corporativo (5 €); copia de seguridad externa cifrada (10 €); herramientas (gestor de contraseñas, vpn) (5 €). El punto de equilibrio, es decir, los clientes necesarios para cubrir solo esos costes fijos, es:

Si solo se vendiera...	Margen por cliente	Clientes para cubrir 60 €/mes	Ingreso neto mensual
Plan Vigía	3,25 €	**19**	155,45 €
Plan Centinela	6,96 €	**9**	185,21 €
Plan Guardián	16,41 €	**4**	214,55 €
Plan Égida	414,65 €	**1**	590,00 €

Tabla 8. Punto de equilibrio operativo. Basta con 19 clientes Vigía, 9 Centinela, 4 Guardián o 1 cliente Égida.

Escenario del primer año (hipótesis prudente). Con la mezcla de clientes de la tabla 9 al cabo de 12 meses:

Plan	Clientes	Ingresos netos	Costes variables	Margen de contribución
Vigía	60	490,91 €	295,91 €	195,00 €
Centinela	25	514,46 €	340,59 €	173,88 €
Guardián	8	429,09 €	297,79 €	131,30 €
Égida	3	1.770,00 €	526,05 €	1.243,95 €
Total	**96**	**3.204,46 €**	**1.460,34 €**	**1.744,13 €**
Costes fijos				−60,00 €
Resultado mensual antes de impuestos				**1.684,13 €**

Tabla 9. Escenario del mes 12: 58,5 horas de analista al mes (unas 13,5 por semana entre los dos socios) y 400 equipos como máximo, que exigen pasar a un despliegue de varios nodos de Wazuh, ya cubierto por los 0,60 €/equipo.

El resultado es antes de impuestos y de cuotas de autónomos, pero las horas de analista ya están pagadas a 20 €/h dentro de los costes variables.

> **Supuestos que habría que verificar antes de vender de verdad:** el precio real del servidor en la nube (se ha estimado, sin presupuesto de proveedor), el coste del seguro de ciberriesgo, el tiempo real de analista por cliente (se mide en el laboratorio durante la demo) y la mezcla de clientes. **Lo que no prometemos:** vigilancia humana 24/7, protección de móviles ni recuperación de datos tras un ataque; el plan Égida puede ampliar el horario cuando haya más personal. Si el tiempo de analista real duplicara lo estimado, Vigía y Centinela quedarían en pérdidas y habría que subir el precio o recortar servicios: por eso el objetivo 8 exige margen positivo en todos los planes.

2.3.2 Financiación

La financiación se plantea en dos fases, para no depender de ninguna subvención:

- **Fase de TFG (recursos propios).** El presupuesto del proyecto es sobre todo mano de obra del propio equipo, aportada en especie. El **desembolso real es de unos 100 €** (SSD externo, dominio y cable de red), a partes iguales entre Lorena y Dani. Los ordenadores ya existen y se imputan por **amortización** (150 €), y todo el software es libre o de evaluación.
- **Fase comercial (recursos propios + ingresos).** Como todos los planes tienen margen positivo desde el primer cliente y los costes fijos son de solo 60 €/mes, la actividad se financia con las propias suscripciones y una pequeña aportación inicial para el seguro y el alta de actividad. No se necesita deuda.
- **Ayudas como acelerador, no como base.** El programa **Kit Digital** (fondos NextGenerationEU) incluye una categoría de ciberseguridad para pymes, y KAIRON podría adherirse como agente digitalizador para ofrecer Égida a pymes con la cuota subvencionada. En las fuentes consultadas la convocatoria de Kit Digital figura **cerrada**, por lo que habría que comprobar en el portal oficial si hay una nueva antes de contar con ella. Otras vías a revisar: el programa **Kit Consulting**, las convocatorias «Pyme Cibersegura» de las cámaras de comercio (2026) y las ayudas autonómicas de ciberseguridad.

Con este planteamiento, el proyecto es viable sin ayudas y las ayudas, si existen, reducen el precio que pagaría el cliente empresa, no el margen de KAIRON.

2.4 Especificación del modelo de solución técnica

2.4.1 Descripción general: arquitectura por capas

Capa	Componentes	Función
1. Endpoints	Agentes Wazuh en Ubuntu y Windows; Sysmon; herramienta forense	Generan y envían los registros (autenticación, procesos, cambios de archivos, registro de Windows). La herramienta forense se ejecuta aquí al haber un incidente.
2. Red y perímetro	pfSense CE (WAN, LAN, Ataque, SOC), NTP, DNS, WireGuard	Segmenta las redes, filtra el tráfico, sincroniza la hora (clave para la hora UTC de las pruebas) y reenvía su propio registro a Wazuh.
3. Recogida y análisis	Wazuh manager, indexer y dashboard	Recibe los eventos, los decodifica, aplica las reglas (estándar y propias), correlaciona y almacena. El panel muestra las alertas.
4. Respuesta y forense	Respuesta activa de Wazuh (firewall-drop) y herramienta forense en Python	Contiene el ataque automáticamente y recoge las pruebas con hora UTC, número de caso y SHA-256.
5. Presentación y negocio	Informes JSON/Markdown, web corporativa (GitHub Pages), planes de suscripción	Convierte lo técnico en algo comprensible para el cliente: informe, panel y servicio contratable.

La figura 1 muestra la topología del laboratorio, repartida en dos PCs. En el **PC-B** viven pfSense y dos redes internas de VirtualBox: la **LAN corporativa** (equipos del cliente simulado) y la red de **Ataque** (Kali); ambas solo se comunican a través de pfSense. En el **PC-A** vive el **SOC** (Wazuh). Los dos PCs se unen con **un cable Ethernet directo** que forma la cuarta red, **SOC / Gestión (192.168.20.0/24)**; los agentes llegan a Wazuh a través de pfSense. Ese cable es el **único adaptador en modo puente**, está aislado del router de casa o del aula (cada PC usa el Wi-Fi para Internet) y no se activa ningún enrutamiento entre el Wi-Fi y el cable.

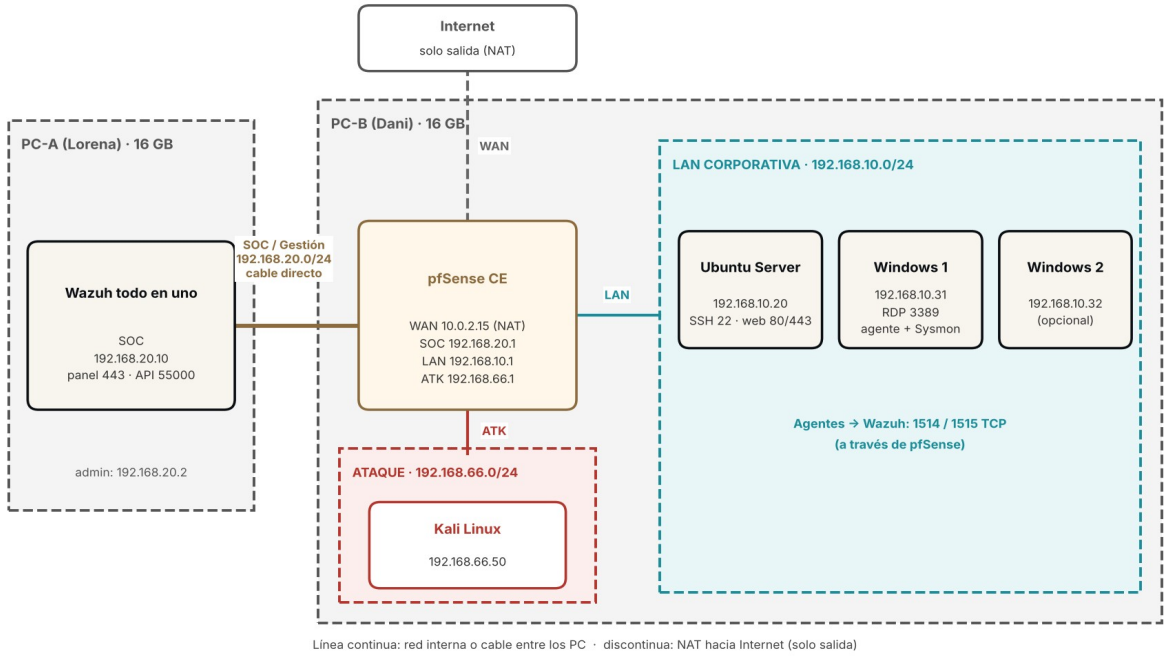


Figura 1. Topología de red del laboratorio KAIRON.

2.4.2 Flujo de datos y operaciones

Secuencia temporal del caso de la demostración (fuerza bruta contra SSH). Los tiempos son los **objetivos** que se medirán en el ensayo:

Instante	Qué ocurre	Componentes	Dato que circula
T+0 s	Kali lanza intentos de acceso SSH (Hydra) contra 192.168.10.20:22, atravesando pfSense.	Kali → pfSense → Ubuntu	Conexiones TCP/22
T+1 a 20 s	sshd registra cada intento fallido como *Failed password* en /var/log/auth.log.	Ubuntu	Líneas de registro
T+≈20 s	El agente Wazuh lee el registro y lo envía cifrado al manager, a través de pfSense y del cable entre los dos PCs.	Agente → pfSense → Wazuh	Evento, 1514/TCP
T+≈25 s	El manager lo decodifica y correlaciona: la regla 100100 (5 fallos en 60 s desde la misma IP) dispara una alerta de nivel 10.	Wazuh manager	Alerta
T+≈30 s	La alerta aparece en el panel y se avisa al analista. La respuesta activa añade la IP atacante al cortafuegos del agente durante 10 minutos.	Wazuh → agente (firewall-drop)	Orden de bloqueo
T+1 a 5 min	El analista confirma que el incidente es real y lanza la herramienta forense en el equipo afectado.	Analista	—
T+≈10 min	La herramienta recoge procesos, conexiones, usuarios e inicios de sesión y persistencia; marca cada prueba con hora UTC, número de caso y SHA-256.	Herramienta Python	Evidencias + hashes
T+≈40 min	Se genera el informe en JSON y Markdown con cronología, evidencias y recomendaciones, y se entrega al cliente.	Informe	Informe de incidente

El segundo ataque sigue el mismo flujo, pero en Windows: el ejecutable simulado crea una tarea programada o una clave *Run*; Sysmon y la monitorización del registro envían los eventos y la regla de persistencia genera la alerta.

2.4.3 Plan de rollback

Toda modificación del laboratorio sigue la misma regla: **copia antes de tocar, prueba antes de aplicar y vuelta atrás automática si falla**. Hay cuatro niveles de protección:

- **Instantáneas de VirtualBox** con nombre *pre-fase-N* antes de cada hito (instalar Wazuh, activar respuesta activa, actualizar el sistema). Permiten volver a una máquina entera en minutos.
- **Copias de configuración:** `ossec.conf`, `local_rules.xml` y los decodificadores de Wazuh, y el `config.xml` de pfSense (que además guarda un historial de versiones restaurables).
- **Exportación OVA** de todas las máquinas al terminar cada hito, guardada en el SSD externo.
- **Git con etiquetas de versión** (v0.1 de la herramienta, v1.0 congelada) para el código y la web; volver atrás es un `git revert` o un *checkout* de la etiqueta.

Para los cambios de reglas, que es lo más frecuente, el procedimiento es **automático**. El script siguiente guarda una copia, valida la configuración con `wazuh-analysisd -t`, reinicia el manager y, si algo falla, restaura la copia sin intervención humana (se probará en el laboratorio antes de darlo por válido):

```
#!/bin/bash
# aplicar-reglas.sh <reglas.xml> : aplica reglas y vuelve atras si fallan
ETC=/var/ossec/etc
COPIA=/var/backups/kairon/$(date +%Y%m%d-%H%M%S)
```

```
mkdir -p "$COPIA"
cp -a $ETC/ossec.conf $ETC/rules/local_rules.xml "$COPIA"/     # 1. copia previa
cp "$1" $ETC/rules/local_rules.xml                              # 2. aplica el cambio
if /var/ossec/bin/wazuh-analysisd -t \
   && systemctl restart wazuh-manager && sleep 20 \
   && systemctl is-active --quiet wazuh-manager; then           # 3. valida y comprueba
  echo "OK: reglas aplicadas (copia en $COPIA)"
else
  echo "ERROR: restaurando la copia anterior"                   # 4. vuelta atras
  cp -a "$COPIA"/local_rules.xml $ETC/rules/ && cp -a "$COPIA"/ossec.conf $ETC/
  systemctl restart wazuh-manager; exit 1
fi
```

Fallo	Cómo se detecta	Vuelta atrás	Tiempo objetivo
Reglas o configuración de Wazuh erróneas	`wazuh-analysisd -t` falla o el manager no arranca	El script restaura `ossec.conf` y `local_rules.xml` automáticamente	Menos de 2 min
Una actualización rompe una VM	La VM no arranca o un servicio no responde	Restaurar la instantánea *pre-fase-N*	Menos de 10 min
Una regla de pfSense deja sin red al laboratorio	Los agentes aparecen como desconectados en Wazuh	Restaurar la versión previa en el historial de configuración de pfSense	Menos de 5 min
La respuesta activa bloquea una IP legítima	Un equipo del laboratorio pierde el acceso	Desbloqueo automático a los 10 min; lista blanca de IP del laboratorio en `ossec.conf`	Menos de 10 min
Fallo de la herramienta forense	Error en la ejecución o informe sin hashes	Volver a la etiqueta anterior de Git; la herramienta solo lee y no modifica el equipo analizado	Menos de 5 min
Se corta el cable entre los dos PCs	Los agentes aparecen como desconectados y pfSense no responde desde el PC-A	Comprobar cable y direcciones del enlace SOC; los agentes guardan los eventos y los reenvían al volver la conexión	Menos de 5 min
VM corrupta o borrada	No arranca ni se puede abrir	Importar la última OVA exportada	Unos 30 min
La web publicada falla	Error 404 o diseño roto en GitHub Pages	`git revert` del último cambio y nueva publicación	Menos de 5 min

2.4.4 Mapa de red y direccionamiento IP

El direccionamiento es estático en servidores y cortafuegos; pfSense reparte por DHCP el rango 192.168.10.100–199 para equipos nuevos de la LAN.

Red	Equipo	IP / máscara	Puerta de enlace	Tipo en VirtualBox
WAN	pfSense (WAN), PC-B	10.0.2.15/24 (DHCP)	10.0.2.2	NAT
LAN corporativa 192.168.10.0/24 (PC-B)	pfSense (LAN)	192.168.10.1/24	—	Red interna *kairon-lan*
	Ubuntu Server	192.168.10.20/24	192.168.10.1	Red interna *kairon-lan*
	Windows cliente 1	192.168.10.31/24	192.168.10.1	Red interna *kairon-lan*
	Windows cliente 2 (opcional)	192.168.10.32/24	192.168.10.1	Red interna *kairon-lan*

Red	Equipo	IP / máscara	Puerta de enlace	Tipo en VirtualBox
Ataque 192.168.66.0/24 (PC-B)	pfSense (OPT1)	192.168.66.1/24	—	Red interna *kairon-atk*
	Kali Linux	192.168.66.50/24	192.168.66.1	Red interna *kairon-atk*
SOC / Gestión 192.168.20.0/24 (cable entre PC-A y PC-B)	pfSense (OPT2)	192.168.20.1/24	—	Adaptador puente al cable
	Wazuh (todo en uno), PC-A	192.168.20.10/24	192.168.20.1	Adaptador puente al cable
	PC-A (administración de Lorena)	192.168.20.2/24	—	Interfaz del cable en el anfitrión
	PC-B (administración de Dani)	192.168.20.3/24	—	Interfaz del cable en el anfitrión
VPN WireGuard 10.10.10.0/24	pfSense / analista remoto	10.10.10.1 / 10.10.10.2	—	Túnel (diseño de producción)

Tabla 10. Direccionamiento IP. pfSense lleva cuatro adaptadores: NAT, LAN, Ataque y SOC. No se usan redes virtuales de Docker porque el laboratorio no emplea contenedores.

2.4.5 Puertos, protocolos y servicios

Servicio	Equipo	Puerto	Origen → destino	Observaciones
Eventos de agentes Wazuh	Wazuh	1514/TCP	Agentes (LAN) → pfSense → Wazuh (192.168.20.10)	Cifrado; canal por el que viaja también la respuesta activa
Alta de agentes (enrolamiento)	Wazuh	1515/TCP	Agentes (LAN) → pfSense → Wazuh	Con contraseña de alta
API de Wazuh	Wazuh	55000/ TCP	PC-A (192.168.20.2) → Wazuh	Solo desde la red SOC / Gestión
Panel web de Wazuh (HTTPS)	Wazuh	443/TCP	PC-A (192.168.20.2) → Wazuh	Certificado TLS; solo red SOC / Gestión
Indexer (OpenSearch)	Wazuh	9200/TCP	Panel → indexer (interno)	No se expone fuera de la VM
Syslog del cortafuegos	Wazuh	514/UDP	pfSense (192.168.20.1) → Wazuh	Registro de pfSense en el SIEM
SSH	Ubuntu	22/TCP	Kali → Ubuntu; PC-B → Ubuntu	Objetivo del ataque 1; protegido con Fail2ban
Web (nginx)	Ubuntu	80, 443/TCP	LAN → Ubuntu	Servicio de ejemplo
RDP	Windows cliente 1	3389/TCP	Kali → Windows (regla expuesta a propósito)	Objetivo del ataque 2
Administración de pfSense (HTTPS)	pfSense	443/TCP	PC-A y PC-B (red SOC / Gestión) → pfSense	Bloqueado desde Ataque y LAN
DNS	pfSense	53/UDP y TCP	LAN → pfSense	Resolución para la LAN
DHCP	pfSense	67/UDP	LAN → pfSense	Rango .100–.199

Servicio	Equipo	Puerto	Origen → destino	Observaciones
NTP	pfSense	123/UDP	LAN → pfSense	Hora común: base de la hora UTC de las pruebas
VPN WireGuard	pfSense	51820/ UDP	Analista remoto → pfSense	Diseño de producción; acceso solo a la red SOC / Gestión

Tabla 11. Puertos de escucha y servicios. En pfSense la política por defecto es denegar y solo se abren los flujos de esta tabla.

Reglas del cortafuegos (resumen). Ataque → LAN: solo 192.168.10.20:22 y 192.168.10.31:3389, simulando servicios expuestos. Ataque → SOC / Gestión y Ataque → Internet: bloqueado, de modo que Kali nunca alcanza a Wazuh. LAN → Wazuh: solo 1514 y 1515/TCP hacia 192.168.20.10. SOC / Gestión → Internet: 53, 80, 123 y 443 de salida, para las actualizaciones de Wazuh. LAN → Internet: 53, 80, 123 y 443 de salida. Red SOC / Gestión → pfSense: administración. Todo lo demás: denegar y registrar.

2.4.6 Medidas de seguridad

Área	Medida aplicada
Aislamiento de red	Cuatro redes separadas por pfSense. El único adaptador en modo puente es el del cable directo entre los dos PCs, aislado de cualquier otra red y sin enrutamiento desde el Wi-Fi. El atacante solo ve los dos servicios expuestos a propósito y nunca el SOC ni Internet.
Cortafuegos	Política de denegar por defecto y reglas mínimas (apartado 2.4.5), con registro de lo bloqueado enviado a Wazuh.
VPN	**WireGuard** en pfSense para el acceso remoto de analistas (diseño de producción): una clave por analista, sin contraseñas, *AllowedIPs* limitado a 192.168.20.0/24 y puerto 51820/UDP.
Contraseñas	Mínimo 14 caracteres o frase de paso, únicas por sistema y guardadas en un gestor. Se cambian las credenciales por defecto de Wazuh y pfSense, el alta de agentes exige contraseña y se activa doble factor en GitHub y en el correo.
Permisos	Mínimo privilegio: cuentas nominales, sin trabajo diario como root o administrador, roles de Wazuh separados (administrador y analista de solo lectura) y herramienta forense que solo lee.
Fail2ban	En Ubuntu, *jail* de sshd con 5 intentos en 10 minutos y bloqueo de 1 hora. En la demo se desactiva para observar la detección de Wazuh y se activa después para comparar ambos bloqueos.
Endurecimiento de SSH	En producción solo se permite clave pública y se prohíbe el acceso de root. En el laboratorio se habilita la contraseña en una cuenta señuelo para poder demostrar el ataque.
Cifrado	TLS en el panel, la API y el indexer; comunicación cifrada entre agentes y manager; cifrado de las copias externas.
Integridad y cadena de custodia	Hora sincronizada por NTP y expresada en UTC, número de caso y SHA-256 de cada prueba, evidencias en una carpeta de solo lectura y registro de quién las recogió y cuándo.
Detección	Monitorización de integridad de archivos en /etc y en las claves Run del registro, Sysmon en Windows y registro de pfSense en el SIEM.
Copias de seguridad	Instantáneas, OVA y copias de configuración (apartado 2.4.3), con una copia en el SSD externo.
Protección de datos (RGPD)	En el laboratorio solo hay datos sintéticos. En producción, contrato de encargado del tratamiento con cada cliente (art. 28 RGPD), minimización de los datos recogidos y retención limitada de 30 a 180 días según el plan.
Seguridad de la web	Política de seguridad de contenido (CSP), *Referrer-Policy* estricta, enlaces externos con `rel="noopener"`, campo trampa anti-spam en el formulario y ninguna cookie ni rastreador.
Uso ético	Los ataques se ejecutan solo dentro del laboratorio aislado, con máquinas propias y sin tocar ninguna red ajena.

Fuentes consultadas

- Wazuh, guía de inicio rápido y requisitos de hardware: https://documentation.wazuh.com/current/quickstart.html
- Programa Kit Digital (Red.es y Ministerio para la Transformación Digital): https://espanadigital.gob.es/lineas-de-actuacion/programa-kit-digital
- Estado de la convocatoria de Kit Digital: https://tecnociminnova.com/es/buscador-ayudas/estatales/est-kit-digital
- Kit Digital 2026, ciberseguridad e IA (TeamSystem): https://teamsystem.es/magazine/kit-digital-2026/
- Kit Consulting, ayudas para asesores en ciberseguridad: https://www.vodafone.es/c/empresas/es/fondos-europeos-next-generation/asesoramiento-digital/kit-consulting/
- Documentos del propio proyecto: PLAN-TFG.md, PLANIFICACION.md, docs/MEMORIA-WEB.md y las páginas de servicios, SOC y productos de la web KAIRON.
- Los precios, la tarifa horaria y los costes de infraestructura son estimaciones del equipo. Uso de IA: apoyo para estructurar el capítulo, calcular las tablas económicas y revisar el texto; todo el contenido ha sido revisado y puede explicarse.